

Lab 5 Report by Alex Cooper

This is a lab report written by Alex Cooper for the fifth lab assignment of CSC472, Software Security. This lab followed the principles of "Kernel Exploitation". This report will detail through text, screenshots, and code snippets the answers to question 1-6 of the lab instructions. I will follow the recommended workflow detailed in the lab.

Question/Task 1: How many folders are there inside the root (/) folder?

```
ls
bin      etc      init      linuxrc   root      sys      usr
dev      home     lib       proc      sbin      tmp
/ $ cd root
sh: cd: can't cd to root
/ $ ls ./root
ls: can't open './root': Permission denied
/ $ cat ./root
cat: can't open './root': Permission denied
/ $
```

There are 11 folders in the root directory "/" but what is inside the actual root folder is unknown, we do not have access to the folder at the beginning of the lab. init and linuxrc are just files but not folders

Question/Task 2: Take a screenshot and show the output after typing the command: "cpio -idmv < rootfs.cpio"

```
student@9f5a8aed56d:~/labs/fs$ cpio -idmv < rootfs.cpio
```

```
.
etc
etc/init.d
etc/passwd
etc/group
bin
bin/su
bin/grep
bin/watch
bin/stat
bin/df
bin/ed
bin/mktemp
bin/mpstat
bin/mkexime
bin/ipcalc
bin/mountpoint
bin/ash
bin/chattr
bin/rmdir
bin/nice
bin/linux64
bin/gzip
bin/sync
bin/sed
bin/run-parts
bin/login
bin/gunzip
bin/rm
bin/chgrp
bin/touch
bin/uname
bin/pwd
bin/rev
bin/printenv
bin/fgrep
```

```
bin/mkdir
bin/iostat
bin/umount
bin/linux32
bin/mount
bin/ew
bin/setarch
bin/sleep
bin/kill
bin/dumpkmap
bin/ping6
bin/ttyhack
bin/catv
bin/dnsdomainname
bin/netstat
bin/ping
bin/setserial
bin/stty
bin/dd
bin/false
bin/lstattr
bin/reformime
bin/busybox
bin/scriptreplay
bin/base64
bin/ps
bin/lis
bin/zcat
bin/conspy
bin/lzop
bin/pidof
bin/fatattr
bin/date
bin/mt
bin/tar
bin/fdflush
bin/pipe_progress
bin/ionice
bin/mknod
bin/dmesg
bin/hostname
bin/echo
```

```
bin/chown
bin/hush
bin/vi
bin/cat
bin/more
bin/chaod
bin/cpio
bin/rpm
bin/true
bin/getopt
bin/egrep
bin/sh
bin/usleep
bin/cp
bin/kbd_mode
bin/fsync
bin/ln
sbin
sbin/ifdown
sbin/iplink
sbin/ifconfig
sbin/ipeigh
sbin/bootchartd
sbin/mkfs.vfat
sbin/losetup
sbin/watchdog
sbin/iptunnel
sbin/halt
sbin/ifup
sbin/modinfo
sbin/swapoff
sbin/init
sbin/rmlevel
sbin/fdisk
sbin/fsck
sbin/mkfs.minix
sbin/reboot
sbin/uevent
sbin/switch_root
sbin/depmod
sbin/acpid
sbin/start-stop-daemon
```

```
sbin/mdev
sbin/tunctl
sbin/sulogin
sbin/sysctl
sbin/logread
sbin/insmod
sbin/ipaddr
sbin/zcip
sbin/ip
sbin/mkswap
sbin/mkfs_ext2
sbin/swapon
sbin/route
sbin/mkdosfs
sbin/iproute
sbin/blkid
sbin/hwclock
sbin/fstrim
sbin/blockdev
sbin/fbsplash
sbin/raidautorun
sbin/hdparm
sbin/slattach
sbin/lsmode
sbin/iprule
sbin/syslogd
sbin/freeramdisk
sbin/poweroff
sbin/klogd
sbin/modprobe
sbin/nameif
sbin/setconsole
sbin/ifenslave
sbin/loadkmap
sbin/mke2fs
sbin/makedevs
sbin/arp
sbin/udhcp
sbin/rmmod
sbin/vconfig
sbin/pivot_root
sbin/devmem
```

```
sbin/getty
sbin/adjtimex
sbin/findfs
sbin/fsck.minix
init
proc
lib
lib/modules
lib/modules/4.4.72
lib/modules/4.4.72/babydriver.ko
sys
usr
usr/bin
usr/bin/uptime
usr/bin/find
usr/bin/unlzop
usr/bin/expand
usr/bin/sv
usr/bin/tail
usr/bin/less
usr/bin/uudecode
usr/bin/resize
usr/bin/printf
usr/bin/cal
usr/bin/md5sum
usr/bin/dos2unix
usr/bin/blkidiscard
usr/bin/pmap
usr/bin/last
usr/bin/cksum
usr/bin/unzip
usr/bin/groups
usr/bin/unlink
usr/bin/runsv
usr/bin/nohup
usr/bin/sha256sum
usr/bin/runsvdir
usr/bin/saenccap
usr/bin/renice
usr/bin/dealloct
usr/bin/basename
usr/bin/logname
```

```
usr/bin/nsenter
usr/bin/lzopcat
usr/bin/head
usr/bin/clear
usr/bin/tty
usr/bin/sha1sum
usr/bin/tac
usr/bin/whois
usr/bin/unlza
usr/bin/patch
usr/bin/hexdump
usr/bin/sort
usr/bin/script
usr/bin/comm
usr/bin/uencode
usr/bin/awk
usr/bin/pscan
usr/bin/traceroute
usr/bin/ewdir
usr/bin/dumpleases
usr/bin/timeout
usr/bin/setkeycodes
usr/bin/ipcrm
usr/bin/od
usr/bin/expr
usr/bin/fold
usr/bin/strings
usr/bin/rpm2cpio
usr/bin/id
usr/bin/mmeter
usr/bin/ipcs
usr/bin/env
usr/bin/dirname
usr/bin/dpkg-deb
usr/bin/truncate
usr/bin/traceroute6
usr/bin/openvt
usr/bin/pwdx
usr/bin/shuf
usr/bin/bcat
usr/bin/ftpget
usr/bin/whoami
```

```
usr/bin/bzip2
usr/bin/hd
usr/bin/unshare
usr/bin/ftpget
usr/bin/which
usr/bin/pgrep
usr/bin/tee
usr/bin/lzcat
usr/bin/eject
usr/bin/envuidgid
usr/bin/top
usr/bin/pstree
usr/bin/bunzip2
usr/bin/lpr
usr/bin/test
usr/bin/xzcat
usr/bin/reset
usr/bin/wc
usr/bin/hostid
usr/bin/unxz
usr/bin/mesg
usr/bin/lsof
usr/bin/svc
usr/bin/passwd
usr/bin/flock
usr/bin/unexpand
usr/bin/man
usr/bin/realpath
usr/bin/uniq
usr/bin/tcpsvd
usr/bin/udpsvd
usr/bin/users
usr/bin/nc
usr/bin/lzma
usr/bin/microcom
usr/bin/free
usr/bin/logger
usr/bin/install
usr/bin/readlink
usr/bin/setuidgid
usr/bin/telnet
usr/bin/diff
```

```
usr/bin/fuser
usr/bin/tr
usr/bin/cut
usr/bin/sha3sum
usr/bin/split
usr/bin/unix2dos
usr/bin/[
usr/bin/setuid
usr/bin/[[
usr/bin/volname
usr/bin/cap
usr/bin/cryptpw
usr/bin/sha512sum
usr/bin/softlimit
usr/bin/killall
usr/bin/showkey
usr/bin/mkpasswd
usr/bin/chpst
usr/bin/sum
usr/bin/mkfifo
usr/bin/ttysize
usr/bin/tftp
usr/bin/yes
usr/bin/pkill
usr/bin/wget
usr/bin/xz
usr/bin/du
usr/bin/lpq
usr/bin/who
usr/bin/rx
usr/bin/dc
usr/bin/nslookup
usr/bin/fgconsole
usr/bin/lsub
usr/bin/dpkg
usr/bin/vlock
usr/bin/chrt
usr/bin/chvt
usr/bin/wall
usr/bin/beep
usr/bin/seq
usr/bin/time
```

```
usr/bin/lspci
usr/bin/xargs
usr/bin/crontab
usr/sbin
usr/sbin/ubirsvol
usr/sbin/crond
usr/sbin/inetd
usr/sbin/l2cdump
usr/sbin/nandwrite
usr/sbin/addgroup
usr/sbin/ntpd
usr/sbin/deluser
usr/sbin/ubiupdatevol
usr/sbin/killall15
usr/sbin/ubidetach
usr/sbin/chroot
usr/sbin/httpd
usr/sbin/nbd-client
usr/sbin/fakeidentd
usr/sbin/adduser
usr/sbin/brc1
usr/sbin/readprofile
usr/sbin/ubirsvol
usr/sbin/tftpd
usr/sbin/rpcwake
usr/sbin/rformat
usr/sbin/chat
usr/sbin/ubirename
usr/sbin/udhcpd
usr/sbin/sendmail
usr/sbin/arping
usr/sbin/ifplugd
usr/sbin/nanddump
usr/sbin/svlogd
usr/sbin/l2cset
usr/sbin/chpasswd
usr/sbin/readahead
usr/sbin/fbset
usr/sbin/popmaildir
usr/sbin/dhcprelay
usr/sbin/ubimkvcl
usr/sbin/delgroup
```

```
usr/sbin/setfont
usr/sbin/ftpd
usr/sbin/telnetd
usr/sbin/l2cdetect
usr/sbin/lpd
usr/sbin/remove-shell
usr/sbin/setlogcons
usr/sbin/rdate
usr/sbin/l2cget
usr/sbin/add-shell
usr/sbin/dnsd
usr/sbin/loadfont
usr/sbin/powertop
usr/sbin/ubiattach
usr/sbin/rdev
usr/sbin/ether-wake
tap
linuxrc
home
home/ctf
5256 blocks
student@09fb5a8aed560: ~/lab5/fs$
```

```
student@09085fc3c0f2: ~/lab5/fs$ ls
bin etc home init lib linuxrc proc rootfs.cpio sbin sys tmp usr
student@09085fc3c0f2: ~/lab5/fs$
```

Question/Task 3: (Inside the QEMU Linux virtual machine) Take a screenshot of the output after typing the command: “./exp”

```
/ $ ./exp
[ 52.899590] device open
[ 52.900815] device open
[ 52.901980] alloc done
[ 52.903047] device release
get root! -- hacked by ALEX COOPER!! *AIRHORN AIRHORN AIRHORN*
/ #
```

Question 4: In the shellcode (exp.c), why do we want to open the device (/dev/babydev) twice?

The second opening of the device is what actually causes the Use-After-Free condition. By opening the device twice, both file descriptors end up referring to the same buffer because the driver uses a global babydev pointer instead of separate per-open buffers. When the buffer is freed or resized through the second descriptor, the driver frees the memory without updating the global pointer, leaving a hanging pointer. This means you have a global pointer accessing memory that no longer exists, which allows a malicious user (or us in this case) to refill that freed area with data that we control.

Question 5: In the shellcode (exp.c), what is the purpose of “ioctl(fd1, 0x1001, 0xa8);” Why use “0xa8”?

The `ioctl()` function is the I/O control function, and this call is applied to the second babydev driver device we opened. By resizing the second babydev device, we trigger the UAF condition. We resize the device to 0xA8 bytes (168 bytes), which matches the size of the kernel's cred structure. This lets the freed babydev buffer get reallocated as our cred object, giving us access to overwrite the creds. The `fd1` argument refers to the file descriptor of the second babydev device (since computers count from index 0). The second argument, 0x1001, is the command code that tells the driver to perform the resize.

Question 6: In the shellcode (exp.c), what is the meaning of “write(fd2, zeros, 28);”?

This writes 28 zero bytes into the overlapped babydev structure, which occupies the same memory as the process's “cred” structure due to the UAF. This clears seven 4-byte fields, which correspond to credential-related values such as UID and GID. Zeroing them effectively removes permission checks because a zero UID/GID corresponds to root. Setting these fields to zero grants full root privileges without corrupting other nearby fields in the credential structure.